

PR #32 — Self-contained parser worker: packaging, licences, integrity gate

Base: `integrate/evidence-search` · Head: `packaging/self-contained-worker`

What this delivers

The forked upload parser loads `pdfjs-dist`, `mammoth` and `mailparser` dynamically in a child process, so the build tracer never sees them and the deployed standalone package previously risked shipping without them. Their inclusion used to depend on `serverExternalPackages / outputFileTracingIncludes` in `next.config.js`, which is platform-managed and reverts on every checkpoint. This PR removes that dependency by pre-bundling the worker and its three heavy dependencies into a single self-contained ES module committed at `public/parser/worker.mjs`, which the launcher forks at runtime. Because the deploy step unconditionally copies `public/` into the standalone artifact, the worker ships regardless of `next.config.js`.

Complete diff (by area)

- `lib/workspaces/parser.ts` — forks the committed `public/parser/worker.mjs` via a runtime-assembled path (so Turbopack does not try to resolve it as a static import). Subprocess isolation, restricted environment, 128 MiB heap cap and 20 s timeout are unchanged.
- `lib/workspaces/parse-file.mjs` — heavy dependencies loaded via dynamic `import()` inside their branches so esbuild can inline them; PDF branch imports the `pdfjs` worker module for its side effect.
- `public/parser/worker.mjs` — the committed self-contained bundle (esbuild 0.28.2; `pdfjs-dist` 6.3.289, `mammoth` 1.12.2, `mailparser` 3.9.23 inlined). sha256 `ac385816...`
- `scripts/parser-worker.config.mjs`, `scripts/build-parser-worker.mjs`, `scripts/check-parser-worker.mjs` — shared esbuild config, the bundler (`yarn build:worker`), and the integrity checker (`yarn check:worker`).
- `public/parser/worker.LICENSES.txt`, `public/parser/worker.manifest.json` — third-party attribution and the integrity manifest (hashes + pinned versions).
- `package.json` — esbuild pinned as an explicit dev dependency at `0.28.2`.
- `.github/workflows/parser-worker-integrity.yml` — required CI gate running `yarn check:worker` on a clean install.

Review fixes included

- **esbuild pinned.** esbuild was only transitive and loosely constrained (`~0.25.0 / >=0.12 <1`) while the byte-identical bundle needs exactly `0.28.2`; it is now an explicit pinned dev dependency. (The repo `yarn.lock` is a git-tracked symlink into the platform store and cannot carry a project-local lock; the pin plus the manifest plus the CI clean-install gate provide reproducibility instead.)
- **Integrity is a required gate.** `yarn check:worker` runs in CI on PRs into `integrate/evidence-search` and `main`. It is intentionally NOT wired into `yarn run build`, so drift blocks merges without ever aborting a production deploy. The CI install deletes the platform lockfile symlink and installs cleanly from `package.json`, proving the bundle reproduces off-platform.

- **Licence attribution completed.** The generator previously skipped packages whose `exports` map blocks `<pkg>/package.json resolution ( deepmerge-ts , dom-serializer , domelementtype , domhandler , domutils , entities , htmlparser2 )`. It now resolves them robustly and throws if any inlined package is unattributed. Attribution now covers 49 packages (was 42); `worker.mjs` is byte-identical, confirming an attribution-only change.

Validation

- Private + PDF suites: 28 pass / 0 fail. Evidence regression: 25 pass / 0 fail.
- `tsc --noEmit` : clean. `prisma validate` : valid. `yarn check:worker` : green (byte-identical rebuild).
- Faithful standalone build (platform packaging with the unmodified platform `next.config.js`): exit 0; `worker.mjs` present in `.build/standalone/app/public/parser/`; `pdfjs-dist` / `mammoth` / `mail-parser` absent from the standalone `node_modules`; no worker-resolution errors.

Limitations

- `public/parser/worker.mjs` is web-accessible (e.g. `/parser/worker.mjs`); it contains only our own non-secret parsing code and the child process receives no application secrets.
- Fixture tests use PGlite and an injected actor/scanner stub; they do not prove production authentication, ClamAV, hosted database concurrency, browser UX or deployment isolation. This PR is a packaging/attribution change and enables no confidential-use feature — all private-workspace flags remain disabled.

Rollback

Revert the merge commit. The worker is a committed static asset with no migration and no runtime dependency change, so reverting restores the previous behaviour with no data or schema impact. No production flag or secret is touched by this PR.